

GRC102 — Week 4 Practical Laboratory

Linux Security Audit and Control-Assurance Report

Student Name: Aganyi Sandra

Course: GRC102

Laboratory: Linux Security Audit, Log Analysis, Lynis and Control Assurance

Lab Environment: Assigned ICDA/ICDFA Linux Virtual Machine

Assessment Date: 07 October 2026

Report Date: 07 October 2026

Evidence Bundle 1 — Auditd Configuration and Events

1.1 Objective

The objective of this activity was to verify Linux audit coverage, monitor security-relevant files and program execution, retrieve audit events, and interpret the resulting evidence from a governance and control-assurance perspective.

1.2 Audit Configuration

The following audit rules were loaded on the assigned Linux VM:

```
-w /etc/passwd -p rwx -k passwd_changes
-w /etc/shadow -p rwx -k shadow_changes
-a always,exit -F arch=b64 -S execve -F key=program_execution
-a always,exit -F arch=b32 -S execve -F key=program_execution
-w /var/log/auth.log -p wa -k auth_failures
```

These rules provide coverage for:

- Changes and access to `/etc/passwd`
- Changes and access to `/etc/shadow`
- Program execution through `execve`
- Changes to `/var/log/auth.log`

The `passwd_changes` and `shadow_changes` rules use `rwx`, which provides broad monitoring coverage but can also generate a large number of routine events because reads and accesses are captured in addition to modifications.

1.3 Audit Event Evidence

A search using:

```
sudo ausearch -k passwd_changes
```

returned audit records associated with `/etc/passwd`.

A particularly relevant event occurred at approximately **09:58:32 on 07 October 2026**. The event included:

- **PATH:** `/etc/passwd`
- **SYSCALL:** successful operation
- `auid=1000`
- `euid=0`
- **Command:** `nano`
- **Executable:** `/usr/bin/nano`
- **Audit key:** `passwd_changes`

The process information indicated privileged execution associated with:

```
sudo nano /etc/passwd
```

Interpretation

The audit system successfully captured access to a critical identity-management file and recorded the user and executable responsible for the activity.

Because the operation was performed through `sudo`, the effective UID was root while the audit UID remained associated with the initiating user. This provides useful accountability for privileged activity.

The event should not automatically be classified as malicious. In the laboratory context, the activity was generated during authorised testing. In a production environment, the same event would require verification against an approved change request.

1.4 Program Execution Evidence

The following command was used:

```
sudo ausearch -k program_execution
```

The audit records included successful execution events involving programs such as:

```
/usr/bin/ip  
/usr/bin/grep
```

One relevant event at approximately **10:13:27 on 07 October 2026** showed:

- type=EXECVE
- Command involving ip
- success=yes
- auid=1000
- uid=1000
- euid=1000
- comm="ip"
- exe="/usr/bin/ip"
- Audit key: program_execution

Interpretation

The `program_execution` rule is functioning and provides visibility into executed commands. This type of monitoring can support detection of suspicious tools, unexpected administrative activity and potentially unauthorised system changes.

Because audit monitoring also captures the commands used to conduct the audit itself, events generated by tools such as `grep`, `ausearch` and `aureport` should be distinguished from suspicious activity.

1.5 Audit Summary

The `sudo aureport` review covered approximately:

07/10/2026 09:45:19 – 07/10/2026 10:15:31

The summary included:

Audit Category	Result
Configuration changes	24
Account/group/role changes	0
Logins	0
Failed logins	0
Authentications	1
Failed authentications	2
Users	3
Terminals	10
Executables	53
Commands	65
Files	101
Failed syscalls	469

Audit Category	Result
Anomaly events	0
Total events	7,693

Interpretation of Audit Summary

The audit subsystem was actively collecting and reporting security events. No login or account/group/role changes were recorded in the reviewed summary. The two failed authentication records should not automatically be treated as an incident because the available summary does not provide sufficient context to determine their cause.

The relatively high number of failed syscalls also should not automatically be interpreted as malicious activity. System utilities and normal Linux operations can legitimately generate unsuccessful system calls.

1.6 Audit Control Assessment

Control status: Partially effective / operational.

The audit configuration provides meaningful coverage of identity files and program execution. However, the broad `rwxa` monitoring approach can create significant event volume and may require tuning in a production environment to distinguish meaningful changes from routine access.

Evidence Bundle 2 — Linux Log Analysis

2.1 Objective

The objective was to review system journal activity, authentication and privilege-use events, and system errors/warnings using the appropriate logging mechanism available on the assigned Linux distribution.

2.2 Journal Review

The following command was executed:

```
sudo journalctl
```

The journal contained normal kernel, service and system activity.

A more focused recent-event review was performed using:

```
sudo journalctl --since "today" -n 20 --no-pager
```

The review identified:

- Successful Xfce configuration service activation
- Scheduled CRON activity
- Audit daemon log rotation
- Successful `sudo` sessions
- Journal review commands

For example, the journal recorded:

```
auditd[21388]: Audit daemon rotating log files
```

Interpretation

Audit log rotation is expected operational behaviour and indicates that the audit subsystem is managing its log files.

The CRON activity was also consistent with scheduled system maintenance.

2.3 SSH Log Review

The following command was executed:

```
sudo journalctl -u ssh --no-pager -n 20
```

The result was:

```
-- No entries --
```

Interpretation

No SSH service entries were available in the current journal for the requested review. This does not prove that SSH is insecure or that no SSH activity has ever occurred; it only confirms that no matching journal entries were available from the reviewed log source.

2.4 Authentication and Privilege-Use Review

The expected `/var/log/auth.log` file was checked using:

```
sudo grep -i "sudo" /var/log/auth.log
```

The system returned:

```
grep: /var/log/auth.log: No such file or directory
```

Because `/var/log/auth.log` was not present, the system journal was used as the equivalent authentication/privilege-use source, as permitted by the laboratory instructions.

The following command was used:

```
sudo journalctl | grep -i "sudo" | tail -20
```

The journal showed successful privileged sessions such as:

```
icdfa : TTY=pts/1 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/sbin/auditctl  
-l
```

and:

```
icdfa : TTY=pts/4 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/journalctl
```

The journal also recorded opening and closing of the privileged sessions.

Interpretation

The logging configuration provides accountability for `sudo` activity by recording:

- Initiating user
- TTY
- Working directory
- Target user
- Command executed
- Session opening and closing

The observed commands were consistent with authorised laboratory activity.

2.5 General System Log Review

The presence of traditional syslog was checked using:

```
ls -l /var/log/syslog
```

The system returned:

```
cannot access '/var/log/syslog': No such file or directory
```

Therefore, `journalctl` was used as the distribution-appropriate source for general system log analysis.

The following command was used:

```
sudo journalctl -p err --since "today" --no-pager
```

The following notable events were identified.

Event 1 — RETBleed Warning

At approximately **09:33:12**, the kernel reported:

```
RETBleed: WARNING: Spectre v2 mitigation leaves CPU vulnerable to RETBleed attacks, data leaks possible!
```

Security significance: High.

This is a security-relevant kernel warning indicating that the current mitigation state may leave the system exposed to a known CPU speculative-execution attack class.

Recommended action: Review the VM's kernel and CPU mitigation status and apply supported updates or mitigations where appropriate.

Event 2 — vmwgfx Hypervisor Error

At approximately **09:33:13**, the kernel reported:

```
vmwgfx ... ERROR ... running on an unsupported hypervisor
```

and:

```
This configuration is likely broken.
```

Security significance: Moderate/operational.

This appears primarily to be a virtual-machine graphics configuration issue rather than evidence of compromise.

Recommended action: Review the VM graphics adapter/driver configuration if graphical instability or related errors occur.

Event 3 — LightDM Session Error

At approximately **09:34:03**, LightDM reported:

```
gkr-pam: unable to locate daemon control file
```

and:

```
pam_systemd(lightdm-greeter:session): Failed to release session
```

Security significance: Low to Moderate.

These messages indicate graphical session-management issues. No evidence from the reviewed logs indicates malicious activity.

Recommended action: Monitor for recurrence and investigate if users experience login/session problems.

Event 4 — Missing Evolution Service

At approximately **09:34:26**, `obexd` reported that:

```
evolution-source-registry.service not found
```

Security significance: Low.

This is primarily a missing service dependency/configuration issue.

Recommended action: Investigate only if the affected functionality is required.

2.6 Module 2 Assessment

The Linux logging control is **operational but dependent on the systemd journal rather than traditional `auth.log` and `syslog` files.**

The review demonstrated:

- Recent system logging
- Traceable privileged activity
- Kernel security warnings
- Service/configuration errors
- Audit log rotation

No reviewed event provided sufficient evidence to classify the VM as compromised.

Evidence Bundle 3 — Lynis Security Assessment

3.1 Lynis Installation and Version

The installed Lynis version was checked using:

```
lynis --version
```

Result:

3.1.4

Therefore, Lynis was already installed and no additional installation was required.

3.2 System Audit

The following command was executed:

```
sudo lynis audit system
```

The audit completed successfully.

Audit Summary

Metric	Result
Lynis version	3.1.4
Tests performed	273
Plugins enabled	1
Hardening Index	65/100
Firewall	Detected
Malware scanner	Detected
Scan mode	Normal
Log file	/var/log/lynis.log
Report file	/var/log/lynis-report.dat

The hardening index of **65/100** indicates that there is meaningful opportunity to improve the system's security baseline.

3.3 Lynis Findings

Finding LYN-F01 — Outdated Lynis Release

The Lynis report contained the following suggestion:

```
This release is more than 4 months old. Check the website or GitHub to see if
there is an update available.
```

Control issue: Security auditing software should be maintained at a supported/current version so that current checks and security recommendations are available.

Risk: An outdated audit tool may have incomplete checks or miss newer security conditions.

Owner: Security/GRC or System Administrator.

Priority: Moderate.

Recommended action: Review the current approved Lynis release and upgrade using an approved package or source.

Retest: Run `lynis audit system` again and verify the version and available tests.

Finding LYN-F02 — Elastic Repository Signature Verification Failure

During the Lynis/package-management checks, the system reported that the Elastic 8.x repository could not be successfully verified.

The reported reason was that the signing key certification relied on SHA-1 and the current security policy rejected the certification.

Control issue: Software repositories must use valid, trusted cryptographic signatures.

Risk: Failure to verify repository signatures can interrupt trusted package updates and creates a software supply-chain assurance concern.

Owner: System Administrator / Infrastructure.

Priority: High.

Recommended action: Update the Elastic repository signing-key configuration using the vendor-supported current signing-key mechanism. Do not disable or bypass signature verification.

Retest: Run the package update process and confirm that the Elastic repository signature is successfully verified without warnings.

Finding LYN-F03 — USB Storage Driver Not Disabled

The Lynis scan reported:

```
Checking usb-storage driver (modprobe config) [ NOT DISABLED ]
```

Control issue: Systems that do not require removable USB storage may restrict or disable USB mass-storage functionality to reduce unnecessary attack surface.

Risk: Uncontrolled removable media can introduce malware, unauthorised data transfer or data-exfiltration opportunities.

Owner: System Administrator / Endpoint Security.

Priority: Moderate.

Recommended action: Determine whether USB storage is required for the assigned system. If it is not required, implement an approved control restricting or disabling USB mass-storage functionality.

Retest: Re-run the relevant Lynis check and confirm the control state.

Finding LYN-F04 — FireWire Driver Not Disabled

The Lynis scan reported:

```
Checking firewire ohci driver (modprobe config) [ NOT DISABLED ]
```

Control issue: Unused hardware interfaces should be restricted where organisational policy permits.

Risk: Unnecessary hardware interfaces increase the system's attack surface.

Owner: System Administrator / Endpoint Security.

Priority: Low to Moderate.

Recommended action: Determine whether FireWire functionality is required. If not required, restrict or disable the relevant driver using an approved configuration.

Retest: Re-run the Lynis audit and confirm the driver control has been addressed.

3.4 Activity 3.3 — Optional Hardening

No hardening change was implemented solely to increase the Lynis score.

This approach follows the laboratory requirement that:

A change should not be made merely to increase the score.

The findings above should first be assessed for applicability, operational impact and authorisation before remediation.

Evidence Bundle 4 — Control Monitoring and Governance

4.1 Control-Monitoring Table

Control / Objective	Evidence	Owner	Observed Status	KPI/KRI or Threshold	Risk / Significance	Remediation	Retest / Follow-up
Monitor changes to critical identity files	ausearch -k passwd_changes; /etc/passwd event involving sudo nano	System Administrator / IAM	Monitoring active; authorised lab activity observed	Any unexplained critical-file modification	Unauthorised identity-file changes could affect account security	Review changes against approved change records	Review future ausearch events and monthly change evidence
Monitor privileged command execution	Journal recorded icdfa → root sudo sessions	System Administrator / Security Operations	Logging operational	Unexpected privileged command = investigation	Unauthorised privilege use could result in system compromise	Review privileged activity against authorised administration	Daily/continuous monitoring; periodic access review
Maintain secure kernel posture	journalctl -p err reported RETBleed warning	System Administrator / Vulnerability Management	Security warning present	High-risk kernel warning = remediation/escalation	Potential exposure to speculative-execution attack	Review kernel updates and mitigation status	Re-run security/log checks after remediation
Maintain trusted software-update channels	Elastic repository signature verification failed	Infrastructure / System Administrator	Control weaknesses identified	Any repository signature failure = investigate	Package integrity/update assurance may be affected	Update repository signing configuration using supported key	Run package update and confirm clean signature verification

Control / Objective	Evidence	Owner	Observed Status	KPI/KRI or Threshold	Risk / Significance	Remediation	Retest / Follow-up
Maintain host security baseline	Lynis hardening index 65/100	System Administrator + Security/GRC	Improvement required	Score below approved baseline triggers review	Security hardening gaps may increase attack surface	Prioritise applicable Lynis findings	Re-run Lynis after approved remediation
Restrict unnecessary removable media	USB storage reported [NOT DISABLED]	Endpoint/System Administrator	Potential control gap	Unauthorised removable media use = escalation	Malware introduction / data-exfiltration risk	Assess business need and restrict if unnecessary	Re-run Lynis and verify driver-control state

4.2 Governance Issues Requiring Attention

At least three evidence-backed conditions warrant governance attention:

GRC-F01 — Repository Signature Verification Failure

This is a significant control-assurance issue because trusted software updates depend on successful cryptographic verification.

GRC-F02 — RETBleed Kernel Warning

The kernel reported a security-relevant mitigation warning. This should be assessed by vulnerability-management/system-administration personnel.

GRC-F03 — Lynis Hardening Index of 65/100

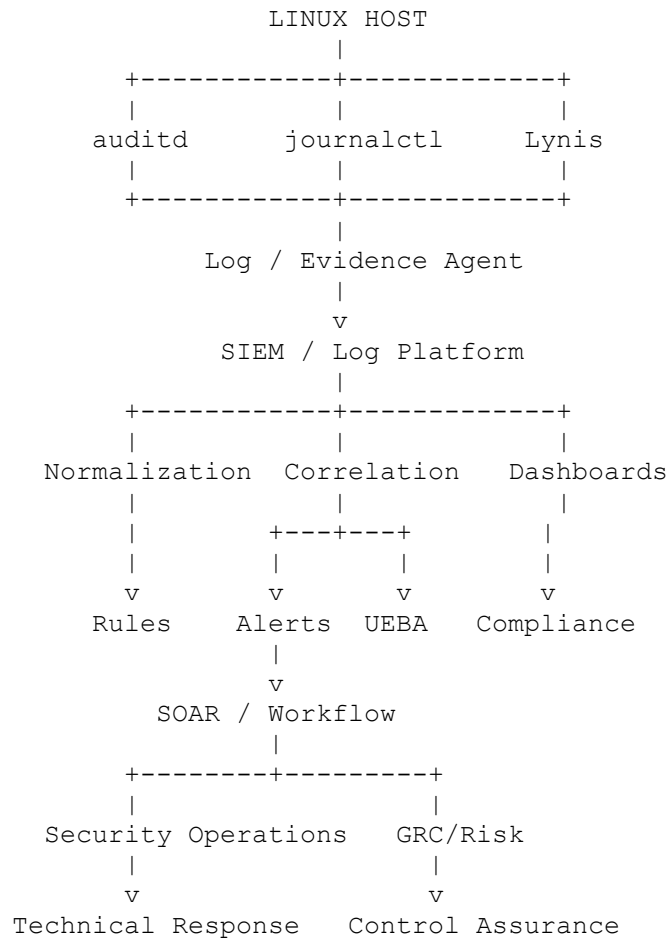
The score indicates that the system has identifiable security-hardening opportunities and should be compared against the organisation's approved baseline.

Additional governance issues include the outdated Lynis release and unrestricted USB storage driver configuration.

Evidence Bundle 5 — SIEM and Automation Mapping

5.1 Enterprise Monitoring Model

The Linux evidence collected during this laboratory can be represented in an enterprise monitoring architecture as follows:



5.2 Evidence-to-SIEM Mapping

Linux Evidence	SIEM/Monitoring Use	Alert Type	Governance Treatment
----------------	---------------------	------------	----------------------

/etc/passwd audit event	Detect critical identity-file modification	Alert when unexpected	Escalate if not linked to approved change
/etc/shadow audit event	Detect sensitive authentication-file activity	High-priority alert	Security/IAM investigation
sudo events	Monitor privileged activity	Alert on unusual user/command/time	Review against privileged-access policy
Failed authentication events	Detect authentication anomalies	Threshold-based alert	Escalate repeated or suspicious activity
Kernel RETBleed warning	Vulnerability/security monitoring	Security warning	Vulnerability-management issue
Repository signature failure	Package supply-chain monitoring	High-priority control alert	GRC/control-assurance issue
Lynis findings	Security-baseline monitoring	Scheduled compliance alert	Risk register/remediation tracking
Hardening index	Trend security posture	Threshold alert	Management/GRC reporting

5.3 Automation Opportunities

The laboratory evidence could support continuous-control monitoring through:

1. **Automated audit-rule verification**
Periodically verify that required audit rules remain loaded.
2. **Privileged-access monitoring**
Alert when privileged commands are executed outside approved administrative windows or by unauthorised accounts.
3. **Critical-file monitoring**
Trigger alerts for modifications to `/etc/passwd`, `/etc/shadow` and other sensitive configuration files.
4. **Automated vulnerability checks**
Schedule Lynis and vulnerability scans and compare results against an approved baseline.
5. **Repository-integrity monitoring**
Alert when package repositories fail signature verification.
6. **Automated reporting**
Produce weekly or monthly control-assurance reports showing open findings, remediation status and retest results.

Evidence Bundle 6 — Final Audit Report

6.1 Executive Summary

This audit assessed the security-control posture of an assigned Linux virtual machine using Linux auditd, systemd journal analysis and Lynis security auditing. The assessment focused on audit coverage, privileged activity, authentication-related logging, system errors and warnings, host hardening, and the translation of technical evidence into governance and continuous-control monitoring.

The audit demonstrated that the Linux audit subsystem was operational and had rules covering critical identity files and program execution. Audit searches successfully retrieved events associated with `/etc/passwd` and program execution. The system journal also provided traceable privileged activity through `sudo`, including the initiating user, terminal, target user and command executed.

Traditional `/var/log/auth.log` and `/var/log/syslog` files were not available on the assigned Kali Linux environment. The systemd journal was therefore used as the appropriate alternative source. Journal analysis identified routine scheduled activity, audit log rotation, privileged sessions and several system warnings.

The Lynis assessment produced a **65/100 hardening index across 273 tests**. Several security-hardening and configuration issues were identified, including an outdated Lynis release, an Elastic repository signature-verification failure, USB storage not being disabled and FireWire not being disabled.

Top Three Findings

1. Elastic repository signature-verification failure — High

The package-management process reported a failure to verify the Elastic repository signature because the relevant signing certification relied on SHA-1, which the current security policy rejected. This is important from a software supply-chain and update-integrity perspective.

2. RETBleed kernel security warning — High

The kernel reported that the current Spectre v2 mitigation leaves the CPU vulnerable to RETBleed attacks. This should be assessed by system administration and vulnerability-management personnel.

3. Lynis hardening index of 65/100 — Moderate

The host has identifiable security-hardening opportunities. The result should be compared with the organisation's approved Linux security baseline and the relevant Lynis findings prioritised according to business and operational requirements.

6.2 Scope and Authorisation

The assessment was performed only against the assigned laboratory Linux virtual machine.

The assessment was limited to:

- Auditd configuration and event collection
- Linux system journal analysis
- Authentication and privilege-use evidence
- System error and warning analysis
- Lynis host security assessment
- Security-control and governance mapping

No unauthorised penetration testing or exploitation was performed.

The activities were conducted for educational laboratory purposes within the assigned VM.

6.3 Methodology

The following methods were used:

Auditd

Audit rules were reviewed using:

```
sudo auditctl -l
```

Events were queried using:

```
sudo ausearch -k passwd_changes  
sudo ausearch -k program_execution
```

Audit summaries were reviewed using:

```
sudo aureport  
sudo aureport -k
```

Journal Analysis

The system journal was reviewed using:

```
sudo journalctl  
sudo journalctl --since "today" -n 20 --no-pager
```

```
sudo journalctl -u ssh --no-pager -n 20
sudo journalctl -p err --since "today" --no-pager
```

Privilege-use activity was reviewed through:

```
sudo journalctl | grep -i "sudo" | tail -20
```

Traditional Log Availability

The presence of authentication and system log files was checked.

/var/log/auth.log was not present.

/var/log/syslog was not present.

Therefore, the systemd journal was used as the equivalent evidence source.

Lynis

Lynis version was verified:

```
lynis --version
```

System audit:

```
sudo lynis audit system
```

Lynis report files:

```
/var/log/lynis.log
/var/log/lynis-report.dat
```

6.4 Findings and Risk Priorities

ID	Finding	Priority	Control Area	Owner
W4-F01	Elastic repository signature verification failure	High	Software supply-chain/update integrity	Infrastructure/System Administrator
W4-F02	RETBleed kernel warning	High	Vulnerability management	System Administrator/Vulnerability Management
W4-F03	Lynis hardening index 65/100	Moderate	Security baseline/hardening	System Administrator + GRC

W4-F04	Lynis release more than four months old	Moderate	Security assessment capability	Security/GRC/System Administrator
W4-F05	USB storage driver not disabled	Moderate	Endpoint attack-surface reduction	System Administrator/Endpoint Security
W4-F06	FireWire driver not disabled	Low–Moderate	Unnecessary hardware-interface reduction	System Administrator

6.5 Remediation Plan

Priority 1 — Repository Signature Verification

Owner: Infrastructure/System Administrator

Action: Review and update the Elastic repository signing-key configuration using the vendor-supported current signing-key mechanism.

Do not: Disable package signature verification or bypass cryptographic validation.

Success evidence: A subsequent package update completes successfully without the repository signature error.

Priority 2 — RETBleed Warning

Owner: System Administrator / Vulnerability Management

Action: Review the current kernel version and available CPU mitigation updates. Confirm whether the warning is addressed by supported kernel or VM configuration changes.

Success evidence: Updated mitigation status and absence/resolution of the relevant security warning following retest.

Priority 3 — Host Hardening

Owner: System Administrator + Security/GRC

Action: Review the Lynis findings against the approved security baseline. Prioritise applicable recommendations rather than changing settings solely to increase the Lynis score.

Success evidence: Repeat Lynis assessment showing resolved applicable findings and documented exceptions for controls that are not operationally appropriate.

Priority 4 — USB Storage

Owner: System Administrator / Endpoint Security

Action: Determine whether USB storage is required. If unnecessary, implement an approved restriction.

Success evidence: Re-run the relevant Lynis check and confirm the control state.

Priority 5 — Lynis Version

Owner: Security/GRC / System Administrator

Action: Review the approved current Lynis version and update the auditing tool where appropriate.

Success evidence: Version verification followed by a new audit using the supported version.

6.6 Retest Plan

Control	Retest Method	Timing
Repository signature	Run package update and verify no signature error	After remediation
RETBleed mitigation	Review kernel/mitigation state and journal	After kernel/VM update

Lynis baseline	Run <code>sudo lynis audit system</code>	After approved hardening
USB storage	Re-run Lynis/driver configuration check	After approved change
FireWire	Re-run relevant Lynis check	After approved change
Privileged activity	Review new journal/audit events	Continuous/periodic
Critical-file monitoring	Run <code>ausearch</code> for audit keys	Continuous/periodic

6.7 Governance Escalation

Highest Priority

The **Elastic repository signature-verification failure** should receive high priority because trusted software-update mechanisms depend on cryptographic verification. A failure in repository validation can prevent reliable security updates and represents a software supply-chain control concern.

The **RETbleed warning** should also be escalated to the appropriate technical owner because it represents a security-relevant kernel mitigation condition.

Escalation Conditions

Escalation to Security, Risk or management should occur when:

- An unauthorised privileged command is detected.
- `/etc/passwd` or `/etc/shadow` is modified without an approved change.
- A critical vulnerability remains unresolved beyond the agreed remediation period.
- Repository signature verification fails for a security-relevant software source.
- A critical security baseline control fails.
- A control repeatedly fails after remediation.

Evidence of Successful Remediation

Closure evidence should include:

- Updated configuration
- Relevant command output
- New audit/journal evidence

- Successful package verification
- Updated Lynis report
- Approved change record
- Retest results
- Documented risk acceptance where remediation is not technically or operationally appropriate

6.8 Conclusion

The assessment demonstrated that the assigned Linux VM has functioning audit and logging capabilities, with meaningful visibility into privileged activity, critical-file access and program execution. The system journal provided useful evidence where traditional authentication and syslog files were not available.

The Lynis assessment produced a hardening index of **65/100**, indicating opportunities to improve the host security baseline. The most significant issues identified were the Elastic repository signature-verification failure and the RETBleed kernel warning, followed by host-hardening opportunities involving USB storage, FireWire and the Lynis version.

From a GRC perspective, the most important outcome is not simply the technical identification of weaknesses but the ability to translate them into measurable controls, ownership, risk prioritisation, remediation and retesting.

The evidence demonstrates how Linux host telemetry can support an enterprise security-monitoring and control-assurance programme. Auditd and journal events can feed a SIEM for detection and alerting, while recurring Lynis assessments and control checks can support continuous-control monitoring and governance reporting.

Overall, the assessed environment has **operational audit and logging controls but requires further hardening and remediation of identified security and configuration weaknesses.**

Appendix A — Security Event / Finding Records

W4-F01 — Elastic Repository Signature Verification Failure

Date/Time Observed: 07 October 2026, during Lynis audit

Evidence Source: Lynis / APT package-management check

Evidence Summary: Elastic 8.x repository signature verification failed because the signing

certification relied on SHA-1, which the current security policy rejected.

Security Significance: Could affect trusted software-update integrity and availability.

Control Objective: Ensure software packages are obtained only from trusted and cryptographically verifiable sources.

Control Owner: Infrastructure/System Administrator

Risk/Priority: High

Recommended Action: Update the repository signing-key configuration using the supported vendor method.

Retest Evidence: Successful package update with no repository signature-verification error.

W4-F02 — RETBleed Kernel Warning

Date/Time Observed: 07 October 2026, 09:33:12

Evidence Source: `journalctl -p err`

Evidence Summary: Kernel reported that the current Spectre v2 mitigation leaves the CPU vulnerable to RETBleed attacks.

Security Significance: Potential exposure to a known speculative-execution attack class.

Control Objective: Maintain supported kernel security mitigations.

Control Owner: System Administrator/Vulnerability Management

Risk/Priority: High

Recommended Action: Review kernel/CPU mitigation status and supported updates.

Retest Evidence: Updated mitigation status and repeat journal/security checks.

W4-F03 — Lynis Hardening Index

Date/Time Observed: 07 October 2026

Evidence Source: Lynis 3.1.4

Evidence Summary: 273 tests were performed and the hardening index was 65/100.

Security Significance: Indicates opportunities to improve the system security baseline.

Control Objective: Maintain an approved and measurable Linux security baseline.

Control Owner: System Administrator + Security/GRC

Risk/Priority: Moderate

Recommended Action: Review applicable Lynis findings and remediate according to risk and operational requirements.

Retest Evidence: New Lynis audit showing improved/resolved applicable findings.

W4-F04 — Critical File Monitoring

Date/Time Observed: 07 October 2026, approximately 09:58:32

Evidence Source: `auditd / ausearch -k passwd_changes`

Evidence Summary: Audit event captured activity involving `/etc/passwd`, with `sudo`, `nano`, root effective privileges and audit key `passwd_changes`.

Security Significance: Critical identity-file activity requires accountability.

Control Objective: Detect and attribute changes/access to sensitive identity files.

Control Owner: System Administrator/IAM

Risk/Priority: Moderate

Recommended Action: Require approved change evidence for production modifications.

Retest Evidence: Audit events linked to approved changes.

W4-F05 — Privileged Activity Monitoring

Date/Time Observed: 07 October 2026, 10:17–10:36

Evidence Source: `systemd journal`

Evidence Summary: Journal recorded `icdfa` opening privileged `sudo` sessions and executing commands as root.

Security Significance: Privileged access requires monitoring and accountability.

Control Objective: Ensure administrative privileges are authorised and traceable.

Control Owner: System Administrator/Security Operations

Risk/Priority: Moderate

Recommended Action: Monitor privileged commands and periodically review administrative access.

Retest Evidence: Subsequent privileged events linked to authorised administration.

Appendix B — Key Command Evidence

Auditd

```
sudo auditctl -l
sudo ausearch -k passwd_changes
sudo ausearch -k program_execution
sudo aureport
sudo aureport -k
```

Journal Analysis

```
sudo journalctl
sudo journalctl --since "today" -n 20 --no-pager
sudo journalctl -u ssh --no-pager -n 20
sudo journalctl -p err --since "today" --no-pager
sudo journalctl | grep -i "sudo" | tail -20
```

Log Source Checks

```
sudo grep -i "sudo" /var/log/auth.log
ls -l /var/log/syslog
```

The system confirmed that neither `/var/log/auth.log` nor `/var/log/syslog` was available, so the systemd journal was used as the equivalent source.

Lynis

```
lynis --version
sudo lynis audit system
sudo grep "^suggestion\[\\]" /var/log/lynis-report.dat
```

Appendix C — Key Evidence Summary

Evidence Area	Actual Result
Audit rules	Critical identity files, program execution and auth-log monitoring configured
<code>/etc/passwd</code> monitoring	Relevant audit event captured
Program execution	<code>/usr/bin/ip</code> and other executions captured
Audit events	7,693 total events in reviewed <code>aureport</code> period
Failed logins	0 in the reviewed <code>aureport</code> summary
Failed authentications	2 in the reviewed <code>aureport</code> summary
Authentication log	<code>/var/log/auth.log</code> absent
System log	<code>/var/log/syslog</code> absent
Privileged activity	<code>sudo</code> activity successfully logged
SSH journal	No entries
Kernel security warning	RETBleed warning observed
Lynis version	3.1.4
Lynis tests	273
Lynis hardening index	65/100
Lynis log	<code>/var/log/lynis.log</code>
Lynis report	<code>/var/log/lynis-report.dat</code>
Lynis suggestion	Installed release more than four months old
Package-management finding	Elastic repository signature verification failure
USB storage	Not disabled
FireWire	Not disabled

Declaration of Evidence Authenticity

All technical evidence presented in this report was obtained from the assigned laboratory Linux environment during the assessment activities. No security events, timestamps, command results or Lynis findings have been intentionally fabricated.

Where the assigned distribution did not provide `/var/log/auth.log` or `/var/log/syslog`, the systemd journal was used as the equivalent evidence source in accordance with the laboratory instructions.

AI assistance was used for report structuring, explanation and language improvement. The underlying commands and technical evidence were independently obtained from the authorised laboratory environment.